

MOSAIC: How to run and present the MVP

1. Start the project

This guide follows the current MVP. It covers setup, a suggested 8-10 minute demonstration, every main feature, and a complete new-evaluation example.

What to say first: "MOSAIC is a local risk-assessment gateway for the external resources an AI coding agent wants to use. It scores packages, skills, MCP servers and URLs, explains the evidence, and returns allow, review or deny."

Before the presentation

1. Install Node.js 22 or newer, which includes npm. Download or clone the MOSAIC repository from <https://github.com/FireFlamingo/MOSAIC>.
2. Open a terminal in the MOSAIC project folder. You should see package.json there. On this computer, the folder is:

```
C:\Users\amogh\OneDrive\Desktop\Assignments\EDI5\MOSAIC
```

3. Run these commands one at a time. The initial dependency installation needs internet access.

```
npm ci
```

```
npm run build
```

```
npm start
```

4. Keep that terminal open. Open <http://127.0.0.1:4318/> in your browser. Wait for "API reachable" in the header.
5. Open Policy. Set Hold for review to 35, Deny the request to 70, and Cross-artifact correlation to on. Click Save policy if you changed anything. These are the defaults used in this guide.
6. Return to Overview. Rehearse once before presenting. Old observations remain saved; you do not need to clear them. Each replay creates a new session.

On presentation day

If dependencies are installed and the build is current, only run npm start, then open the same browser address. The built app and bundled fonts work locally without internet. Rebuild after changing the source. Stop the server afterwards with Ctrl+C in its terminal.

For development only, npm run dev serves the interface on port 4317 and the API on 4318. Use the single-server build above for a simpler presentation.

2. Suggested live presentation sequence

- 1. Introduce Overview (about 1 minute).** Show the total evaluations, allowed requests, pending reviews and denied requests. Explain that the supplied examples are synthetic inputs processed by the real local engine. The figures come from stored records, so totals depend on previous runs.
- 2. Show a straightforward Allow (30 seconds).** Click Replay workflow, then Known publisher install. The new package scores 0 and is Allowed with the default policy. Explain: "No configured risk indicators matched the supplied evidence. This does not independently certify the package as safe."
- 3. Demonstrate session correlation (about 2 minutes).** Replay Linked trust signals. The Session trace shows a URL followed by a skill. The URL scores 100 and is Denied. The skill scores 43 and Needs review. Click the skill node and show What informed this decision. Its own metadata contributes 25; prior session activity adds 6 and the reused name adds 12.
- 4. Show filtering and navigation (30 seconds).** Close the details. Use the session dropdown to choose a session. Click View session to see only that session's requests. In Requests, try the artifact-type buttons, decision dropdown and search box. Clear filters before moving on.
- 5. Create an evaluation live (about 2 minutes).** Click New evaluation and enter the example on page 3. Submit it, show the 41-point breakdown, expand Supplied metadata & content, and point out the session, original decision and hash-linked receipt.
- 6. Resolve a review (about 1 minute).** In the resulting details, enter this Reviewer note: "Presentation example: reviewed the supplied metadata." Click Allow request. Show the recorded human review. Close the details and open Review queue: the resolved request is no longer pending. Its original score remains 41. A fresh replay of Young integration needs review provides another held request if you want to demonstrate Deny request instead.
- 7. Demonstrate policy (about 1 minute).** Open Policy and move the Decision preview slider. Scores 0-34 are allowed, 35-69 need review, and 70-100 are denied under the defaults. The preview creates no records. Turn correlation off and save; replay Linked trust signals again. Its skill now scores 25 and is Allowed. Restore correlation to on afterwards. Existing evaluations do not change.
- 8. Finish with the audit trail (30 seconds).** Click Export audit trail, or Download audit on Overview. Show the downloaded mosaic-audit.json file. Explain that records persist across restarts and that original evaluation receipts can be checked offline.

Closing sentence: "This MVP demonstrates one explainable scoring and review workflow across four artifact types. Automatic interception and independently verified evidence are work for the final project."

3. How to create a new evaluation

Use review 35, deny 70 and correlation on. Choose a fresh session ID, such as presentation-review-01, to keep unrelated earlier activity out of this example. Use -02, -03 and so on for later rehearsals.

Enter this complete example

1. Click **New evaluation** in the upper-right area. On a narrow screen, it appears below the page heading. The keyboard shortcut is N when you are not typing in a field.
2. Select **MCP server** under Artifact type. This selects the kind of resource being assessed; it does not connect to a real server.
3. Set **Artifact name** to presentation-notes.
4. Set **Session ID** to presentation-review-01, or another fresh ID.
5. Set **Source** to https://example.invalid/tools. This is a synthetic example address and is not fetched.
6. Leave **Artifact existence** as Unknown.
7. Set **Signature** to Reported unsigned.
8. Set **Age in days** to 6.
9. Set **Downloads** to 18.
10. Expand **Content & permissions**. Enter "Summarise the selected project notes." as Static content. Check only network:egress; leave the other permissions unchecked.
11. Click **Evaluate request**. The evaluation details should open automatically.

What you should see

Expected result: 41/100, Needs review. The points are: existence unverified 8; unsigned artifact 10; very new artifact 8; low observed adoption 7; elevated network permission 8. Total: $8 + 10 + 8 + 7 + 8 = 41$. This assumes the default policy and no earlier activity in that session.

The details show each reason and its points, request context, the original decision, supplied metadata/content and the receipt hash. Enter a Reviewer note, then choose Allow request or Deny request. Without a non-empty note, the review buttons stay disabled.

What the fields mean

Artifact name and Session ID are required. A session groups related requests; reuse an ID only when you want their history connected. Source is an optional location label. For Remote URL, fill URL to evaluate with a full URL; if omitted, the engine tries the artifact name as the URL.

Existence and signature values are reports supplied by you, not independently verified facts. Unknown means the information was not supplied. Age and downloads are optional non-negative whole numbers. Leave them blank when unknown: entering zero explicitly means an age of zero or zero downloads. Text and permissions are optional static evidence. Nothing submitted is installed, fetched or executed.

4. Feature checklist

Four artifact types. Package assesses a software library request. Skill assesses agent instructions or rules. MCP server assesses a proposed external tool server. Remote URL assesses a proposed URL. All use one request format and the same scoring/review workflow.

Risk scoring and explanations. The deterministic engine totals signal points, caps the score at 100, and applies policy thresholds. Rules cover reported existence, package-name similarity, age, adoption, signature status, elevated permissions, static content patterns, URL properties and session history.

Overview and totals. See total, allowed, pending-review and denied counts. Click a total to open the corresponding request list. Overview includes the active policy summary, session trace, decision stream and review inbox.

Session trace. Choose a session from its dropdown, inspect individual events and open View session. The visual trace shows the latest five events; the request list contains the session's full recorded history. Related earlier requests can add points to later evaluations.

Search and filters. Requests supports artifact-type buttons, a decision dropdown, search by artifact name/source/session, a session filter, clear filters and pagination. Search is case-insensitive. N opens an evaluation, / focuses search, and Escape closes dialogs.

Evidence inspector. Open an artifact name, its inspect arrow, a trace node or a review card. See the score, verdict, signal breakdown, timestamp, source, session, scoring time, original decision, submitted evidence and SHA-256 receipt hash.

Review inbox and queue. The inbox highlights held requests; Review queue lists pending decisions. A required note accompanies each human Allow or Deny. The resolved verdict is displayed without changing the original score or receipt. A resolved review cannot be reviewed again through this UI.

Policy editor. Type thresholds or use sliders; review must be lower than deny. Save policy, discard edits, toggle correlation, and try a score in Decision preview. Changes apply to future evaluations; previewing alone creates no evaluation.

Four replay workflows, using default policy. Known publisher install: score 0, Allowed. Young integration needs review: score 41, Needs review. Linked trust signals: URL 100, Denied, followed by skill 43, Needs review. Over-privileged unknown source: score 97, Denied. Replays use the real API and always get fresh session IDs.

Storage, export and integration. Evaluations, reviews and policy persist in data/state.json. Export the audit as JSON and verify the original evaluation chain offline. A local HTTP API supports evaluations, reviews, policy, replay, state retrieval, health and export; a cooperating caller must obey its decisions.

Usability. The layout adapts to desktop and mobile. Refresh loads the latest saved state. Failed submissions retain the form; Reconnect lets you retry. Replay supports keyboard arrows. Manrope headings and Public Sans interface text are bundled with the app.

5. Questions and quick fixes

What the MVP does and does not prove

Does Allow install or run the artifact? No. MOSAIC records a decision. It never executes the submitted artifact. An integrating agent or caller would have to use the decision before proceeding.

Does it already protect all agent activity automatically? No. Automatic command interception, agent adapters, MCP proxying and HTTP enforcement are not implemented in this MVP.

Does it verify the registry, website or signature? No. Metadata and text come from the caller. URL checks parse the address locally. Live registry lookups, reputation feeds and signature verification are future work.

Is 41 a 41% chance of an attack? No. It is a sum of configured heuristic points. A low score does not establish safety. The test fixtures are not a research benchmark, and detection accuracy has not been measured against the full planned corpus.

What is special about correlation? Earlier non-allowed evaluations of other artifact types in the same session can raise a later score. Matching names add another signal. The engine considers the latest 20 earlier session evaluations and their original policy decisions.

Are receipts digitally signed? No. Original evaluations are SHA-256 hash-linked. Verification can detect changed content or broken links, but cannot authenticate the author or detect an entirely rewritten chain. Review and policy events are recorded separately and are not authenticated by that chain.

If something goes wrong during the demonstration

npm is not recognised: install Node.js 22 or newer and reopen the terminal. **package.json cannot be found:** move into the MOSAIC folder before running the commands.

The browser will not open the app / Gateway offline: check that npm start is still running, use `http://127.0.0.1:4318/`, then choose Reconnect or the header refresh button. If the terminal says the port is already in use, check whether an existing MOSAIC server is already running.

A result differs from this guide: restore review 35, deny 70 and correlation on. Use the exact example values and a new session ID. Do not interpret older records as new results: policy changes do not rescore them.

The review queue is empty: replay Young integration needs review, or submit the example on page 3.

A request is missing: clear type, decision, search and session filters, then check the next page. **The look appears outdated:** rebuild the project and refresh the browser.

To verify an export: from the project folder run the following, replacing the quoted path with the actual downloaded file location:

```
npm run verify:audit -- "C:/path/to/mosaic-audit.json"
```

For an optional pre-presentation check, run `npm run check` and `npm run test:browser`. Browser tests use installed Edge on Windows; on other platforms, install the test browser with `npx playwright install chromium` first. These tests use separate temporary data, leaving your saved presentation records intact.